IT Risk Assessment & Control Evaluation

FinSecure Ltd – UK FinTech Company

Risk assessment conducted on a fictional organisation to demonstrate practical application of Governance, Risk, and Compliance (GRC) principles.

Prepared by:
Pruthviraj Patil

Date:
19 April 2026

Contents

Executive Summary 3
Company Overview 3
Scope & Objectives 4
Asset Identification 5
Risk Assessment Methodology 6
Risk Identification 7
Risk Analysis (Risk Assessment Table) 8
Existing Controls 9
Control Gaps 10
Risk Treatment / Control Recommendations 11
Residual Risk 13
Compliance & Framework Alignment 14
Conclusion 14

Executive Summary

This risk assessment was carried out for FinSecure Ltd, which is a fintech company that offers digital payment solutions in the United Kingdom. The objective of conducting this assessment is to identify, analyse and prioritize some of the most important cybersecurity risks faced by FinSecure Ltd.

Some of the main risks discovered during the process included phishing attacks aimed at the company's employees, unauthorized access to sensitive financial data, and potential misconfiguration of cloud services. These risks pose a significant threat to the confidentiality, integrity, and availability of critical information and systems used by the organization.

The general risk level of the organization is considered to be high mainly because of the sensitivity of the data handled by the organization and the use of cloud infrastructure.

In order to mitigate these risks, it is recommended that the organization implement measures such as improved access controls, increased awareness training for employees, enhanced monitoring and logging, as well as efficient backup and recovery procedures.

Company Overview

FinSecure Ltd is a FinTech firm operating in the United Kingdom which offers online payments for businesses and individuals. The firm supports online transactions and payment processing and storage.

Data collected by the firm includes very sensitive data such as customers' financial and personal data that should be protected from any type of threat in order to protect the customers' interests as well as the firm's reputation.

The firm uses a cloud-based infrastructure which supports several important resources. Payment processing systems, customer database, employee workstations, and email systems fall under this category.

Because of the high value of the data handled by the firm, FinSecure Ltd faces several different cyber-risks. Risks come from both external and internal sources. Phishing attacks and other cyber-risks constitute an example of external risk faced by FinSecure Ltd while internal risks include insider threats and misconfiguration of access controls.

In conclusion, FinSecure Ltd requires effective governance, risk management, and cybersecurity control mechanisms.

Scope & Objectives

Scope

The current risk assessment is aimed at the vital systems and aspects related to the provision of digital payment services by the company, FinSecure Ltd.

The scope consists of the following elements:

Systems covered:

- Payment processing system
- Customer database systems
- Cloud hosting infrastructure for applications and databases
- Employees' endpoint devices (workstations and laptops)
- Communication systems and email

Data Types:

- PII - Personal information identifying an individual
- Financial customer data
- Transaction data
- Company internal and operational data

Processes within Company:

- Management of client accounts
- Handling payments and transactions
- Company communications and data exchange processes
- Access and identity management procedures

Objectives

Objective of this risk assessment is to:

- Identify any possible cybersecurity risks on key data and systems
- Likelihood and consequences of any identified risks
- Existing controls and their efficiencies in mitigating those risks
- Areas where there is room for improving existing controls
- Risk management strategies to mitigate identified risk exposures

Beyond the Scope of This Assessment

The following is not within the scope of this assessment:

- Outside service providers
- Physical security measures (e.g., building entry, video surveillance)
- Legacy applications that are not essential to payments

Asset Identification

Asset identification is a crucial component of the risk management process, which involves determining the resources that need to be protected.

For FinSecure Ltd., the following are some assets that have been considered critical for business operations:

Customer Data

- It consists of personally identifiable information (PII), financial data, and transaction logs.
- Customer data is among the most important assets because exposure could attract regulatory fines, financial losses, and harm the company's reputation.

Payment Processing Platform

- It facilitates transactions made by the company's clients.
- Any disruptions or breaches of security in this platform could affect the availability of the service offered.

Cloud Computing Infrastructure

- FinSecure Ltd. utilizes cloud computing technology to host applications, databases, and services.
- Security vulnerabilities or configuration errors in this asset could put at risk sensitive data and applications hosted within the cloud environment.

Employee Devices

- Employees use their laptops and desktops to access applications and systems containing sensitive information.
- These endpoints could be targeted by attackers to launch malicious activities like malware and phishing attacks.

Email System

- It provides an avenue for internal and external communication.
- It is a popular asset among cybercriminals because of its widespread usage; phishing is the most prevalent threat to the email system.

Risk Assessment Methodology

The risk assessment has been carried out in an orderly and systematic manner with the aim of identifying, evaluating, and prioritizing potential cybersecurity risks that could impact FinSecure Ltd.

Approach for Identifying Risks

Identification of risks was done by assessing the organization's key assets, systems, and processes. Threats typical for the fintech industry were considered, including cyber threats from outside as well as inside the company.

Risks were identified in terms of where sensitive data is managed and where critical processes are performed.

Likelihood Scale

Each risk is considered based on its likelihood by the following scale:

- **Low (1):** Unlikely to happen; infrequent or negligible past instances
- **Medium (2):** Potential to happen if specific conditions apply
- **High (3):** Will probably happen; frequent or common threat

Impact Scale

The impact of each identified risk is measured by evaluating its effect on business activities, security of information, and legal requirements:

Low (1): Minor effect with little impact on the business

Medium (2): Considerable impact on the operations or finances of the business

High (3): Major impact, resulting in losses or penalties for violating the law

Risk Scoring Approach

Risk score will be calculated for each risk using the following equation:

Risk Score = Likelihood * Impact

Score will be used to ascertain the degree of risk as follows:

- **1-2:** Low Risk
- **3-4:** Medium Risk
- **6-9:** High Risk

This risk scoring approach facilitates prioritization of risks for the organization and helps to concentrate efforts where the impact is greatest.

Approach Compliance

This approach has been designed to comply with established risk management approaches and frameworks such as:

- **ISO 27001:** Risk Management related to Information Security
- **NIST Cybersecurity Framework:** Risk Identification and Mitigation

Risk Identification

As part of the assessment of critical assets, systems, and business processes for FinSecure Ltd, the following possible cybersecurity threats have been noted. The listed cybersecurity threats relate to typical issues experienced by organisations involved in the fintech industry and can influence their capacity to ensure security and confidentiality of their information.

Risk of Unauthorised Access to Sensitive Information

There is a possibility of unauthorised persons getting access to customer information or FinSecure Ltd's computer systems due to vulnerabilities in access management. This may lead to loss of information or any other harmful consequences.

Threat of Phishing Scams against Employees

The employees may be the target of phishing and social engineering scams aimed at gaining credentials of employees and deploying malware. Given the importance of email communication, it poses a serious threat to the company.

Data Breach through Cloud Configuration Failure

Poor configuration of cloud computing may lead to breach of data confidentiality since cloud environments need active security management to prevent any breach.

Internal Attack/Misuse (Malicious or Accidental)

Attack or misuse by insiders refers to employees with authorized access who might use systems or information for unauthorized activities.

System Outage and Unavailability of Services

Outage or failure of important IT systems, poor infrastructure, and cyber-attacks such as denial of service (DoS) can cause unavailability of payment systems.

Data Loss Caused by Poor or Non-existent Back-ups

Failure of back-up systems or poor practices can lead to loss of data in case of cyber-attack or system failure.

Risk Analysis (Risk Assessment Table)

The listed risks have been analyzed considering their probability of occurrence and possible effects on the organization. The risk level has been determined through calculation using the outlined risk analysis methodology.

Risk ID	Risk Description	Likelihood	Impact	Score	Risk Level	Reason
R1	Unauthorized access to sensitive financial data	Medium (2)	High (3)	6	High	Weak or misconfigured access controls may allow unauthorised access
R2	Phishing attack targeting employees	High (3)	High (3)	9	High	High likelihood due to human vulnerability and frequent attack patterns
R3	Data breach due to cloud misconfiguration	Medium (2)	High (3)	6	High	Improper cloud settings may expose sensitive data externally
R4	Insider threat (malicious or accidental)	Medium (2)	High (3)	6	High	Excessive access privileges and lack of monitoring
R5	System downtime and service disruption	Medium (2)	Medium (2)	4	Medium	Infrastructure or service failures may impact operations
R6	Data loss due to backup failure	Low (1)	High (3)	3	Medium	Lack of regular backup testing may result in data loss

Existing Controls

FinSecure Ltd has established several controls that are used to secure their information systems and operations. The controls have been put in place to mitigate risks by FinSecure Ltd, although they might need further improvements.

Access Control Controls

FinSecure Ltd uses multi-factor authentication and role-based access control mechanisms for some of its information systems to ensure that only authorized individuals have access to them.

Effectiveness: Partially Effective

The company does not use multi-factor authentication effectively on its critical systems, especially administrative accounts.

Security Awareness Training

Employees are offered basic security awareness training when they first join the organization. The training includes essential cybersecurity measures, such as email and password safety tips.

Effectiveness: Limited Effectiveness

There is no regular training, and no simulations to check the security awareness levels of staff members are conducted.

Processes for Backing up Data

There are processes put in place to ensure that data that is lost or damaged can be recovered.

Effectiveness: Partly Effective

It seems like there are backups in place, but it does not seem like backups have been regularly tested.

Cloud-Based Infrastructure Security

Security measures have been established within the cloud-based infrastructure to ensure security of applications/data hosted.

Effectiveness: Partly Effective

Misconfiguration risks cannot be ruled out because there is no monitoring or regular security assessments.

Logging and Monitoring

Simple logging is in place to monitor users' activity and any changes made within the environment.

Effectiveness: Limited Effectiveness

There are no centralised logging and monitoring process or advanced detection capabilities.

Control Gaps

Based on the gap analysis of controls available, a few gaps have been identified in the current security strategy of FinSecure Ltd. The identified gaps create an opportunity for potential cyber threats and may expose the organization to many risks.

Gaps in Implementation of Multi-Factor Authentication

Multi-factor authentication is not implemented across all the crucial systems and especially on any privileged account(s).

Gaps: The lack of MFA implementation creates the risk that the user credential could be exploited by any external parties or attackers.

No Security Awareness Training for Employees

Security training is conducted only during induction training, with no further training after the induction process.

Gaps: This might make employees unaware of phishing or social engineering attack techniques and how to prevent them.

Inadequate Monitoring and Lack of Centralized Log Management

Logs are maintained; however, there is no monitoring solution in place and thus no real-time alert capabilities.

Gaps: Incident detection might be difficult and could take time.

Non-Vetted Backup and Data Restoration Procedures

There are already backups in place, but there are no regular tests conducted to ensure that the restoration of the backup takes place.

Gap: Data restoration in the event of a system crash or ransomware infection will be unreliable.

Security Configurations of Clouds

The cloud infrastructure is not checked to detect any security misconfigurations.

Gap: Any possible misconfiguration of the storage and access controls could lead to an accidental breach of the data confidentiality.

Insufficient Access Control Permissions Management

Access levels of users are not checked in accordance with the user role.

Gap: Such a situation may increase the likelihood of an inside threat.

Risk Treatment / Control Recommendations

Taking into consideration the risk assessment findings, the following measures should be considered to address these risks. The main method will be that of risk mitigation by improving technical and organizational controls.

R1 – Unauthorized Access to Sensitive Information

Controls to Consider:

- Enable multi-factor authentication for all systems, especially for privileged users
- Implement role-based access control
- Follow the principle of least privilege
- Carry out access reviews regularly

Risk Treatment Approach: Mitigation

R2 – Phishing Attack Against Employees

Controls to Consider:

- Provide employees with security training on a regular basis
- Conduct phishing simulation testing
- Consider deploying email security products

Risk Treatment Approach: Mitigation

R3 – Data Breach from Misconfigured Cloud Environments

Controls to Consider:

- Regularly conduct security configuration reviews for cloud environments
- Implement cloud environment configuration best practices
- Automate cloud environment security monitoring

Risk Treatment Approach: Mitigation

R4 - Insider Threat (Intentional or Unintentional)

Recommended Controls:

- Ensure tight access controls
- Implement activity monitoring
- Deploy Data Loss Prevention (DLP) controls

Risk Treatment Approach: Mitigation

R5 - System Unavailability/Downtime

Recommended Controls:

- Ensure system redundancy and high availability architecture
- Develop incident response plan
- Perform regular maintenance and monitoring

Risk Treatment Approach: Mitigation

R6 - Data Loss from Failed Backup

Recommended Controls:

- Automate backup process
- Test backup procedures
- Secure backup data

Risk Treatment Approach: Mitigation

Other Possible Risk Treatment Approaches

Besides mitigation, other strategies can also be adopted based on the specific business scenario:

- Risk Avoidance - By avoiding certain business activities altogether
- Risk Transfer - By transferring the risk to another party through insurance
- Risk Acceptance - If mitigation costs outweigh the benefits

Residual Risk

Given the deployment of the suggested controls, the risk levels are anticipated to be lowered. Nonetheless, one must bear in mind that not all risks can be eradicated; instead, some degree of residual risk will persist in the company.

Residual risk entails the risk level that continues to exist despite mitigation actions. They must be monitored and managed throughout the risk management process.

R1 – Unauthorized Access to Sensitive Data

Residual Risk Level: Medium

In spite of the use of MFA, RBAC, and access evaluations, credential exposure or manipulation may still occur, particularly via innovative attack vectors.

R2 – Phishing Exploit on Staff Members

Residual Risk Level: Medium

As a result of consistent instruction and phishing tests, human mistakes will still happen, making it possible for employees to be duped by more advanced phishing scams.

R3 – Data Breach from Poorly Configured Cloud Environments

Residual Risk Level: Medium

Although risk can be minimized through review and monitoring, misconfiguration can still happen due to mistakes by users or complexity within the system.

R4 – Insider Threat (Mistaken or Purposeful)

Residual Risk Level: Medium

Monitoring and security measures might still not mitigate the threat from an insider because humans can always do the unpredictable.

R5 – Downtime

Residual Risk Level: Low to Medium

Downtime risks are now minimized with the help of monitoring and redundancy; nevertheless, there is still potential for problems.

R6 – Loss of Data Through Poorly Executed Backup

Residual Risk Level: Low to Medium

The risks can now be significantly lowered, but not completely eradicated with proper monitoring and automation.

Compliance & Framework Alignment

In view of the risk assessment results and recommendations on the controls that are required, the methodology used for the risk assessment is consistent with recognized practices. Thus, FinSecure Ltd will be able to ensure a structured approach to assessing the risks associated with cybersecurity.

General Data Protection Regulation (GDPR)

Personal data security, including customer finances and PII, has been considered during the assessment. Recommended controls, such as access control, data protection, and monitoring, can help comply with GDPR requirements.

ISO/IEC 27001

The risk assessment procedure and recommendations for controls are consistent with the requirements of ISO 27001 when it comes to setting up, implementing, and running an ISMS. Several critical processes like access control, risk management, and continuous monitoring can be compared with ISO 27001 Annex A controls.

NIST Cybersecurity Framework

This assessment is guided by key components of the NIST Cybersecurity Framework - Identify, Protect, Detect, Respond, and Recover. The systematic identification of risks, implementation of controls, and improvement in detecting and responding capabilities fit the standards of the framework.

Conclusion

Through conducting the risk assessment, it is possible to identify several critical cybersecurity risks associated with FinSecure Ltd. Access controls, susceptibility to phishing attacks, vulnerabilities related to cloud services, and limitations with monitoring are some of the most significant risks which can affect the confidentiality, integrity, and availability of sensitive systems.

According to the results obtained, it can be stated that although some controls are already implemented, there are certain gaps in the way they function. Eliminating these gaps is critical for decreasing the risk of FinSecure Ltd.

To address the identified risks, specific control measures should be taken. The implementation of MFA, improvement of security awareness, additional measures related to monitoring and logging, and tests regarding the process of backup restoration will decrease the probability of identified risks significantly. Nevertheless, even after implementing all these measures, some residual risk may be present.

In conclusion, through the use of a methodical and risk-based process, which is consistent with established guidelines like ISO/IEC 27001 and the NIST Cybersecurity Framework, as well as compliance with legal obligations like GDPR, FinSecure Ltd can strengthen its defence against cyber-attacks and safeguard its vital resources.

Consistent evaluation, surveillance, and refinement of controls will be necessary for sustaining an adequate level of cybersecurity amidst a dynamic threat environment.